第十五讲教学设计：用户认证与权限控制

课程信息

项目	内容
课程名称	Java Web应用开发 (Java Web Application Development)
课次	第15讲（共16讲）
教学主题	用户认证与权限控制（Authentication & Authorization）
授课时长	45分钟
教学方式	双语教学（英文授课，关键术语中英文对照）
适用对象	计算机科学与技术专业本科三年级，已修完前14讲
先修知识	Session会话管理、Filter过滤器、DAO模式、MVC架构
教学场所	多媒体机房（每人一机，可运行IDE与浏览器）

一、教学目标

知识目标 (Knowledge Objectives)

1. 区分认证（Authentication）与授权（Authorization）的概念与流程。
2. 掌握基于会话（Session-Based）的登录态维护与注销（Logout）机制。
3. 掌握基于角色（RBAC: Role-Based Access Control）的访问控制思路与过滤器（Filter）实现方式。
4. 了解密码安全（Password Security）：摘要与散列（Hash），理解SHA-256原理，了解生产级推荐算法BCrypt/Argon2。

能力目标 (Ability Objectives)

1. 能实现登录、登出、会话保存登录用户信息与基本的失败提示。
2. 能编写基于角色的权限过滤器，对`/admin/*`等受限路径实施访问控制。
3. 能在JSP视图层按角色动态渲染菜单。

4. **能在AI安全攻防平台中识别SQL注入、越权访问、Session劫持等漏洞并完成修复。**
5. **能使用AI工具辅助代码审查，发现权限控制缺陷并批判性评估AI的建议。**
6. **能在"人 vs AI"代码评审对战中进行有效的批判性辩论，区分AI的有效建议与误报。**
7. **能设计验证方案，通过多角色测试路径验证系统安全性。**

素质目标 (Quality Objectives)

1. 树立"最小权限原则"与"默认拒绝"的安全意识。
2. 形成合规观与责任心：妥善保管用户敏感信息，不在日志中明文打印密码。
3. **培养AI协作素养：理解AI是辅助工具而非替代品，建立"AI建议->人工判断->验证确认"的工作范式。**
4. **培养数据驱动意识：理解学情数据如何指导教学决策，体会过程数据对学习改进的价值。**
5. **[思政融合]** 以"制度先行、权责明晰"比喻RBAC，强调依法治网、守护秩序与公平正义。

二、学情分析

知识基础

- **已掌握：**HttpSession的创建与属性存取（第5讲）、Filter过滤器与过滤链机制（第11讲）、三层架构与DAO模式（第13讲）、数据库事务与连接池（第14讲）。
- **待建立：**认证与授权的区别、RBAC模型、Session安全管理（invalidate vs removeAttribute）、前端菜单与后端权限的一致性。

能力水平

- 学生已能独立编写Servlet + JSP + Filter的完整Web应用，具备基本的调试与排错能力。
- 对安全问题缺乏系统认识，容易将"能登录"等同于"安全"，忽视越权访问风险。
- 分组协作能力良好，前序课程已有多次分组实验经验。

AI素养现状

- 经过前14讲的系统训练，学生的AI使用能力已显著提升：第13讲中学生已能使用Cursor生成三层架构代码骨架并完成架构审查；第14讲中学生已能向Claude描述业务场景获取隔离级别建议并进行批判性评估。多数学生已建立"AI生成->人工审查->验证确认"的基本协作流程。
- **已具备的AI能力**：能使用结构化提示词与AI对话（第13讲训练）；能对AI的技术方案建议进行"同意/存疑/反对"的分层评估（第14讲训练）；能在AI生成的代码中识别结构性问题（如层间耦合、职责越界）。
- **待提升的AI能力**：尚未将AI应用于安全漏洞诊断这一更高阶场景——安全问题具有隐蔽性强、需要攻防视角、涉及多文件关联分析等特点，对AI提示词设计和输出评估能力提出更高要求；学生对AI在安全领域的能力边界（可能遗漏漏洞或给出过度建议）缺乏认知。
- **课前数据驱动的学情把握**：通过WebDev助教的课前预习交互记录与TeamCoach的团队项目周报，教师已掌握学生在认证与授权方面的具体困惑和团队协作中的薄弱环节，可据此实施精准教学。
- 本讲作为AI应用的集中展示课，通过四大AI创新工具（智能体、攻防闯关、项目教练、评审对战）的综合运用，引导学生从"被动接受AI答案"转向"主动利用AI发现问题、自主判断、动手验证"，完成从代码生成到架构审查再到安全诊断的AI应用能力三级跃迁。

三、教学重点与难点

教学重点

1. 认证（Authentication）与授权（Authorization）的区别及串联实现。
2. 基于角色的权限过滤器（RoleBasedAuthFilter）的核心逻辑。
3. Session安全管理：`invalidate()` vs `removeAttribute()` 的本质区别。
4. **AI驱动的安全攻防闯关中漏洞识别与修复的完整流程。**
5. **AI代码评审对战中"人 vs AI"的批判性对比与辩论方法。**

教学难点

1. 前端菜单隐藏 ≠ 后端权限控制——理解"纵深防御"思想。
2. 会话残留导致的安全隐患——退出不彻底的连锁后果。
3. **对AI审查结果的批判性判断——AI可能遗漏问题或给出过度建议，学生需要区分"有效建议"与"噪音"。**

4. 安全攻防闯关中的综合漏洞分析——需要跨文件关联理解、攻防视角转换。

四、教学资源与平台工具

教学资源

资源	说明
示例工程（问题版）	课程作业管理系统，故意保留3个权限缺陷，供学生诊断
示例工程（修复版）	对应的正确实现，作为课堂修复的参照与备用
分组任务卡（A/B/C组）	每组聚焦不同代码模块，含审查文件清单与AI提示词
AI提示词卡片	6类结构化提示词，覆盖审查、对照、修改、验证、纠偏等场景
测试验证清单	5项核心测试用例，覆盖核心权限、视图一致性、Session行为
知识点参考表	6大知识点的定义、英文、系统体现对照表

自主研发AI教学工具

工具名称	定位	应用阶段	核心功能
WebDev助教（课程教学智能体）	课程专属AI助教	课前预习 + 课中即时答疑 + 课后辅导	基于课程知识库的RAG问答、预习引导、学情热力图、知识薄弱点分析
WebSec挑战（安全攻防闯关平台）	AI驱动的游戏化安全训练	课中实战闯关	AI动态生成漏洞代码、自动判定修复、实时数据大屏、排行榜
TeamCoach（团队项目AI教练）	团队协作智能监控	课前数据展示 + 课后持续追踪	Git贡献度分析、搭便车预警、AI周报生成、分工合理性检测
Code Review Battle（AI代码评审对战）	人机对抗式代码审查	课中评审对战	人工审查 vs AI审查对比、评分维度可视化、辩论引导

通用平台工具

工具	用途
IntelliJ IDEA / Eclipse	代码编辑与调试
Tomcat 9+	运行Web应用

工具	用途
浏览器开发者工具	观察Session、Cookie、HTTP状态码
AI工具（Cursor / ChatGPT / Claude）	学生自主探索、教师课堂演示
Marp课件	课堂投影

五、教学流程与时间安排

> *以下流程与录课视频内容一一对应，45分钟内集中展现全部4项AI创新工具。*

阶段一：数据驱动导入（0-5分钟，5min）

教师活动

1. **展示WebDev助教学情数据**：打开WebDev助教后台，投影展示课前学情数据面板：
    - "课前42人向智能体提问，热点TOP3：Session过期处理、角色判断、Cookie安全"
    - "据此，今天重点讲Session安全管理和角色权限控制"
    - 投影展示提问频次热力图和知识薄弱点分析，体现数据驱动教学决策。
2. **展示TeamCoach周报摘要**：投影团队项目AI教练的最新周报：
    - "第3组Service层无人负责，第5组赵六连续两周贡献不足"
    - "据此，今天课堂上我会重点关注这些同学的表现"
    - 投影全班各组贡献度对比图，让学生直观看到数据驱动的教师决策过程。
3. **现场演示权限漏洞**：打开"课程作业管理系统"：
    - 用`admin/admin123`登录，展示正常功能。
    - 用`tom/tom123`（普通用户）登录，演示异常行为：tom登录后首页菜单出现"管理后台"入口；tom点击后成功进入后台页面。
4. **抛出核心问题**（投影大字）：**"如果一个普通用户登录后也能进入管理后台，这个系统安全吗？"**

学生活动

- 观看学情数据展示，确认自己课前提出的问题是否在热点中。
- 观看TeamCoach周报，了解自己团队的协作状况。
- 观察系统漏洞演示，思考安全问题成因。

设计意图

- 用WebDev助教的真实学情数据开场，展示AI如何驱动教学决策，体现"数据驱动导入"而非传统的经验导入。
- TeamCoach周报展示让学生感受到过程数据的真实监控效果，增强团队协作责任感。
- 权限漏洞演示制造认知冲突，将抽象的"认证与授权"概念具象化为可验证的系统bug。

涉及AI创新

- 创新一：**WebDev助教** — 学情数据采集与展示
- 创新三：**TeamCoach** — 团队项目周报展示

阶段二：安全攻防闯关（5-20分钟，15min）

教师活动

1. 规则说明（2min）：
    - 打开WebSec挑战平台，投影展示第15讲的5个安全关卡（SQL注入、越权访问、Session安全、XSS跨站脚本、综合BOSS关）。
    - 说明规则："AI为每人生成不同的漏洞代码，找到漏洞->写修复代码->自动测试->过关。题目不同，无法抄袭，排行榜实时更新。"
    - 投影展示AI生成漏洞代码的过程，让学生直观看到AI出题机制。
2. 学生闯关（8min）：
    - 学生在平台上完成第1-3关（SQL注入、越权访问、Session安全）。
    - 教师巡视，同时关注实时数据大屏：各关通过率、平均用时、当前排名。
3. 数据驱动干预（5min）：

- 教师看到实时数据大屏显示"第2关（越权访问）通过率仅40%"。
- 暂停闯关，集中讲解Filter权限检查的核心逻辑：

```
Authentication → 你是谁？    → LoginServlet验证用户名密码
Authorization  → 你能做什么？→ RoleBasedAuthFilter检查角色

Filter核心判断逻辑：
User user = (User) session.getAttribute("user");
if (user == null || !"ADMIN".equals(user.getRole())) {
    response.sendError(403);  // 拒绝访问
    return;
}
chain.doFilter(request, response);  // 放行
```

- 用代码投影对比"有Filter"和"无Filter"的请求处理流程，帮助学生理解拦截机制。
- 讲完后学生继续挑战。

学生活动

- 在WebSec挑战平台上逐关挑战，分析AI生成的漏洞代码，编写修复方案。
- 遇到困难时可参考平台提示（提示而非答案），也可向WebDev助教提问。
- 集中讲解时认真听讲，对照自己闯关中遇到的困难理解Filter逻辑。

设计意图

- 游戏化安全训练将枯燥的安全知识转化为闯关挑战，激发学生参与热情。
- AI为每人生成不同漏洞代码，天然防抄袭，确保每位学生独立思考。
- 实时数据大屏让教师精准发现共性薄弱点，实现"数据驱动即时干预"——在学生最需要时讲解最关键的知识点。
- 先闯关再讲解的顺序让学生带着"亲身体验的困惑"听讲，理解更深刻。

涉及AI创新

- **创新二：WebSec挑战** — AI动态出题、游戏化闯关、实时数据大屏

阶段三：AI代码评审对战（20-35分钟，15min）

教师活动

1. **任务分配**（1min）：
    - 打开Code Review Battle平台，投影展示对战界面。
    - 分A/B/C三组，展示待审查代码（`LogoutServlet.java`——包含Session管理、注销逻辑、安全处理等多个审查点）。
    - 说明规则："先人工审查，再AI审查，最后对比辩论——看谁找的问题更准、更全、更有价值。"
2. **第一轮：人工审查**（5min）：
    - 各组分析`LogoutServlet.java`代码，找出所有安全问题。
    - 每组记录：问题位置、风险描述、修复建议。
    - 教师巡视，观察各组讨论深度。
3. **第二轮：AI审查**（2min）：
    - 教师将同一段代码提交给AI（投影展示完整AI分析过程）。
    - AI输出审查报告，逐项列出发现的问题。
4. **第三轮：人 vs AI 对比辩论**（8min）：
    - 各组代表汇报：我们找到了什么？AI找到了什么？
    - 教师引导三个维度的对比：
        - **AI找到但学生没找到的** -> 学习机会："AI帮我们发现了盲区，这个知识点我们还需加强。"
        - **学生找到但AI遗漏的** -> 人类优势："我们比AI更懂业务上下文！这说明AI不能替代人的判断。"
        - **AI误报（给出错误建议）** -> 批判性思维训练："AI说这里有问题，但其实没有。为什么AI会误判？"
    - 教师总结：**人机协同的最佳模式** —— AI覆盖面广、速度快，但人类在业务理解、优先级判断、上下文关联方面有不可替代的优势。最佳实践是"AI扫描+人工验证+协作改进"。

学生活动

- 第一轮：各组认真审查代码，独立发现安全问题，不使用任何AI工具。
- 第二轮：观看AI审查过程，记录AI发现的问题列表。

- 第三轮：对比自己的发现与AI的发现，积极参与辩论，发表对AI建议的采纳或拒绝意见及理由。

设计意图

- "人 vs AI"的对抗形式天然有张力，激发学生的竞争意识和参与热情。
- 三轮对比设计系统性地培养批判性思维：先独立思考，再对照AI，最后辩论评估。
- AI误报是最有价值的教学时刻——学生发现"AI也会犯错"，从而建立成熟的AI协作观。
- 人类优势的展示增强学生自信，避免对AI的过度依赖或恐惧。

涉及AI创新

- 创新四：**Code Review Battle** — 人机对抗式代码审查、批判性辩论

阶段四：修复实践与验证（35-42分钟，7min）

教师活动

1. 分组修复（4min）：
    - 各组根据攻防闯关和评审对战中发现的问题，修复示例工程中的权限缺陷。
    - 提醒学生：遇到不理解的知识点可随时向WebDev助教提问。
    - 教师巡视，**重点关注TeamCoach周报中标记的薄弱学生**（如"第5组赵六"），提供针对性指导。
2. 验证演示（3min）：
    - 教师用修复后的代码运行系统，执行测试清单逐项验证：

编号	测试场景	操作	预期结果
T1	未登录访问后台	直接访问`/admin/panel`	重定向到登录页
T2	普通用户越权	tom登录后访问`/admin/panel`	返回403
T3	管理员正常访问	admin登录后访问`/admin/panel`	正常进入

编号	测试场景	操作	预期结果
T4	退出后拦截	退出后再访问`/admin/panel`	重定向到登录页
T5	菜单一致性	tom查看首页菜单	无"管理后台"入口

学生活动

- 各组协作修复代码，在自己的环境中验证修复效果。
- 遇到问题向WebDev助教提问，获取即时知识点解答。
- 使用测试清单逐项确认修复效果。

设计意图

- 修复过程是"从知到行"的转化——经过攻防闯关的漏洞识别和评审对战的深度分析，学生已充分理解问题，此时动手修改并验证。
- WebDev助教在此阶段作为即时答疑工具，实现个性化学习支持。
- 教师根据TeamCoach数据精准关注薄弱学生，体现数据驱动的差异化教学。
- 测试清单将"验证"制度化，培养学生"改完必测"的工程习惯。

涉及AI创新

- 创新一：**WebDev助教** — 课中即时答疑
- 创新三：**TeamCoach** — 数据驱动关注薄弱学生

阶段五：总结与反思（42-45分钟，3min）

教师活动

1. 展示本节课数据：
    - 攻防闯关通过率（投影WebSec挑战平台大屏：各关通过率、全班平均用时）。
    - 评审对战"人 vs AI"得分对比（投影Code Review Battle平台评分面板）。
    - WebDev助教本节课实时提问记录（展示课中即时问答的频次与热点）。

2. **知识点总结**（投影展示三个核心收获）：
    - 认证回答"你是谁"，授权回答"你能做什么"。
    - RBAC + Filter = 后端权限控制的基本骨架。
    - AI帮你发现问题，但理解和验证是你的责任——人机协同才是最佳模式。
3. **课程思政**：以RBAC的"制度先行、权责明晰"类比社会治理——任何系统都需要规则和边界，技术人员的责任是构建公平、安全的数字秩序，保护用户权益，遵守法律法规。结合《个人信息保护法》实施背景，强调开发者的法律义务。
4. **课后布置**：
    - 完成WebSec挑战平台剩余关卡（第4-5关：XSS跨站脚本、综合BOSS关）。
    - 团队项目中实现权限控制模块，TeamCoach将持续追踪进度和贡献度。
    - 有任何疑问随时向WebDev助教提问，获取24小时个性化辅导。

学生活动

- 回顾本节课的学习数据，反思自己在攻防闯关和评审对战中的表现。
- 记录核心知识点与课后任务。

设计意图

- 用多维数据回顾替代传统总结，让学生直观看到自己的学习轨迹。
- 三个核心收获覆盖知识（认证vs授权）、技能（RBAC+Filter）、素养（人机协同）三个维度。
- 课程思政自然融入，不生硬说教。
- 课后任务与4项AI工具无缝衔接：攻防闯关延续课中训练、TeamCoach持续追踪项目、WebDev助教提供24小时答疑。

涉及AI创新

- **创新一：WebDev助教** — 课后持续辅导
- **创新二：WebSec挑战** — 课后延续闯关
- **创新三：TeamCoach** — 课后持续追踪

六、AI应用环节说明

> *本节完整说明本讲中4项自主研发AI工具的使用设计，是人工智能赛道的核心环节。*

6.1 AI工具总览

工具	类型	核心技术	使用者	主要场景
WebDev助教	课程专属教学智能体	RAG + 国产大模型（DeepSeek/通义千问）	学生 + 教师	课前预习问答、学情数据采集、课中即时答疑、课后持续辅导
WebSec挑战	AI安全攻防闯关平台	大模型动态生成漏洞代码 + JUnit自动判定	学生	课中游戏化安全训练、漏洞识别与修复
TeamCoach	团队项目AI教练	Git log分析 + AI周报生成 + 贡献度建模	教师 + 学生	团队协作监控、搭便车预警、课前数据展示
Code Review Battle	AI代码评审对战平台	AI审查引擎 + 人机对比评分	学生 + 教师	课中人机协同审查、批判性思维培养

6.2 工具与教学阶段映射

教学阶段	**WEBDEV助教**	**WEBSEC挑战**	**TEAMCOACH**	**CODE REVIEW BATTLE**
阶段一：数据驱动导入（0-5min）	**学情数据展示**	—	**周报摘要展示**	—
阶段二：安全攻防闯关（5-20min）	即时答疑（辅助）	**核心平台**	—	—
阶段三：AI代码评审对战（20-35min）	—	—	—	**核心平台**
阶段四：修复实践与验证（35-42min）	**即时答疑**	—	**关注薄弱生**	—
阶段五：总结与反思（42-45min）	提问记录展示	通过率数据展示	—	对战评分展示
课前	**预习问答+学情采集**	—	**周报生成**	—

教学阶段	WEBDEV助教	WEBSEC挑战	TEAMCOACH	CODE REVIEW BATTLE
课后	**24h持续辅导**	剩余关卡	持续追踪项目	—

6.3 各工具设计目的

WebDev助教（课程教学智能体）：

1. **课前学情采集**：通过学生与智能体的预习交互，自动采集知识薄弱点，生成学情热力图，支撑教师的数据驱动教学决策。
2. **课中即时答疑**：学生在攻防闯关或修复代码时遇到知识盲区，可即时向智能体提问，获得基于课程知识库的精准回答，而非通用AI的泛泛之谈。
3. **课后个性化辅导**：24小时可用，为不同层次学生提供个性化学习路径推荐。
4. **数据闭环**：智能体交互日志 -> 学情分析 -> 教师决策 -> 下次课调整，形成持续改进的数据闭环。

WebSec挑战（安全攻防闯关平台）：

1. **游戏化激发参与**：将枯燥的安全知识转化为闯关挑战，排行榜和竞争机制激发学生主动学习。
2. **AI个性化出题**：AI为每位学生生成不同的漏洞代码，天然防抄袭，确保独立思考。
3. **即时反馈与自适应**：提交修复代码后自动测试判定，失败时给提示不给答案，引导学生深入思考。
4. **数据驱动干预**：实时数据大屏让教师精准发现共性薄弱点（如"第2关通过率仅40%"），实现即时教学干预。

TeamCoach（团队项目AI教练）：

1. **过程性团队监控**：通过Git提交分析自动检测搭便车现象，用数据而非主观判断评价团队贡献。
2. **教师精准关注**：周报中标记的薄弱学生和风险团队，帮助教师在课堂上实施差异化指导。
3. **工程化习惯培养**：让学生习惯于持续集成、规范提交、团队协作的工程化工作方式。

Code Review Battle（AI代码评审对战）：

1. **培养批判性思维**：通过"人 vs AI"对战，学生不再盲从AI，而是主动评估AI建议的准确性。
2. **展示人机互补**：AI覆盖面广但可能误判，人类业务理解深但可能遗漏——最佳模式是协同合作。
3. **安全意识深化**：在对抗性学习中，安全问题从抽象概念变为需要辩论的具体发现。

6.4 综合操作流程

```
课前准备：
  WebDev助教发布预习任务 → 学生课前提问 → 智能体采集学情数据
  TeamCoach分析Git记录 → 生成团队周报 → 教师据此调整课堂重点
          ↓
阶段一（0-5min）：数据驱动导入
  教师展示WebDev助教学情数据面板 → 确定今日教学重点
  教师展示TeamCoach周报摘要 → 标记重点关注学生
  现场演示权限漏洞 → 抛出核心问题
          ↓
阶段二（5-20min）：安全攻防闯关
  打开WebSec挑战平台 → 学生闯关（第1-3关）
  教师看实时数据大屏 → 发现共性薄弱点 → 暂停闯关集中讲解
  学生遇到困难时可向WebDev助教提问
          ↓
阶段三（20-35min）：AI代码评审对战
  打开Code Review Battle → 分组展示待审查代码
  第一轮：学生独立审查（5min）
  第二轮：AI审查（2min，教师投影展示）
  第三轮：人 vs AI对比辩论（8min）→ 教师总结人机协同模式
          ↓
阶段四（35-42min）：修复实践与验证
  各组修复代码 → WebDev助教即时答疑
  教师根据TeamCoach数据关注薄弱学生
  运行测试清单验证修复
          ↓
阶段五（42-45min）：总结与反思
  展示WebSec通过率 + Battle对战评分 + 智能体提问记录
  知识总结 + 思政融入 + 课后任务布置
          ↓
课后延续：
  学生完成WebSec剩余关卡 → 向WebDev助教提问 → TeamCoach持续追踪项目
```

6.5 预期效果

维度	传统课堂	AI赋能课堂（4工具）	可量化指标
学情把握	教师凭经验判断	WebDev助教提供课前学情热力图	课前提问覆盖率>=70%，教师据此调整>=2个教学重点
安全知识习得	教师讲解+学生被动接受	WebSec闯关主动探索+失败中学习	第1-3关平均通过率>=60%，课后完成率>=85%
问题发现效率	学生逐行阅读，15min仍有遗漏	攻防闯关+评审对战双轮驱动	三组汇报覆盖全部3个预埋缺陷，知识点命中率100%
批判性思维	难以系统训练	Code Review Battle人机对比辩论	每组至少提出1条对AI建议的有效质疑（误报/遗漏）
团队协作意识	课堂难以观测	TeamCoach数据驱动关注	周报标记学生的后续贡献提升>=30%
学生参与度	被动听讲为主	闯关+对战+辩论多形式互动	全员参与攻防闯关，辩论环节发言覆盖率>=90%
个性化支持	课堂难以兼顾	WebDev助教24h即时答疑	课中+课后智能体交互次数>=人均3次
过程数据沉淀	仅有期末成绩	闯关数据+对战评分+提问记录+贡献度报告	每位学生产生>=4维度的过程性评价数据

6.6 防滥用措施

1. **工具边界明确**：每项AI工具的角色被严格限定——WebDev助教是"答疑助手"不是"代写工具"，WebSec挑战是"出题+判定"不是"给答案"，Code Review Battle中AI审查结果需经人工辩论才有价值。
2. **个性化防抄袭**：WebSec挑战中AI为每人生成不同漏洞代码，天然防止照抄；Code Review Battle中学生先独立审查再看AI结果，确保独立思考在先。
3. **批判性评估强制**：Code Review Battle的辩论环节强制要求学生对AI建议做出"采纳/拒绝"判断并说明理由，防止盲从AI。
4. **教师纠偏机制**：教师在攻防闯关中通过数据大屏即时干预，在评审对战中引导辩论方向，在修复环节中根据TeamCoach数据精准指导。
5. **验证闭环**：攻防闯关的自动测试和修复阶段的测试清单构成双重验证闭环，确保学生不仅"知道问题"还能"解决问题"。
6. **智能体交互监控**：WebDev助教记录所有交互日志，教师可回溯查看学生提问质量，对"让AI直接给答案"的不当使用进行教育引导。

七、教师—学生—AI工具 四方活动表

时间	阶段	教师活动	学生活动	WEBDEV助教	WEBSEC挑战	TEAMCOACH	CODE REVIEW BATTLE
课前	数据准备	查看学情数据，调整教学重点	向智能体提问预习问题	采集学情数据，生成热力图	—	分析Git记录，生成周报	—
0-5min	数据驱动导入	展示学情数据和周报，演示漏洞	观看数据，思考问题	提供学情面板	—	提供周报摘要	—
5-20min	安全攻防闯关	巡视+看数据大屏+即时干预讲解	完成第1-3关闯关	即时答疑（辅助）	AI出题+自动判定+大屏	—	—
20-35min	AI代码评审对战	分组+投影AI审查+引导辩论	人工审查->观看AI审查->辩论	—	—	—	人机对比+评分+辩论
35-42min	修复实践与验证	巡视指导（关注薄弱生）+验证演示	修复代码+向智能体提问+测试验证	即时答疑	—	数据指导关注重点	—
42-45min	总结与反思	展示多维数据，总结知识点+思政	回顾数据，记录要点	提问记录展示	通过率展示	—	对战评分展示

时间	阶段	教师活动	学生活动	WEBDEV助教	WEBSEC挑战	TEAMCOACH	CODE REVIEW BATTLE
课后	延续学习	查看智能体日志和闯关数据	完成剩余关卡+项目开发+提问	**24h持续辅导**	**第4-5关**	**持续追踪项目**	—

八、教学方法与手段

教学方法

1. **数据驱动导入 (Data-Driven Introduction)**：以WebDev助教学情数据和TeamCoach周报开场，用真实数据驱动教学决策。
2. **游戏化安全训练 (Gamified Security Training)**：通过WebSec挑战平台的闯关机制，将安全知识习得转化为主动探索。
3. **人机对抗式学习 (Human-AI Adversarial Learning)**：Code Review Battle中"人 vs AI"对战，培养批判性思维和AI协作素养。
4. **场景驱动 (Scenario-Driven)**：从"普通用户能进管理后台"的可观察缺陷入手，制造认知冲突。
5. **分组协作 (Group Collaboration)**：A/B/C三组分别聚焦不同模块，辩论时形成互补。
6. **测试驱动验证 (Test-Driven Verification)**：使用测试清单逐项验证修复效果。
7. **双语教学法 (Bilingual Teaching)**：
    - 英文授课，关键术语中英文对照（Authentication, Authorization, RBAC, Session, Filter）。
    - 代码注释与变量命名使用规范英文。

教学手段

- IDE（IntelliJ IDEA / Eclipse）
- Tomcat 9+ 服务器
- 浏览器开发者工具（观察Cookie、Session、HTTP状态码）
- **WebDev助教（课程教学智能体）**
- **WebSec挑战（安全攻防闯关平台）**

- **TeamCoach**（团队项目AI教练）
- **Code Review Battle**（AI代码评审对战）
- AI工具（Cursor / ChatGPT / Claude）
- Marp课件投影

九、教学评价

过程性评价

评价维度	评价指标	数据来源	评价方式
安全攻防能力	各关通过率、修复代码质量、用时效率	WebSec挑战平台数据	闯关通关数据自动记录
AI协作能力	人 vs AI评审得分对比、辩论中的有效质疑数量	Code Review Battle平台评分	对战评分+教师评估
学习主动性	课前/课中/课后向智能体提问的频次与质量	WebDev助教交互日志	提问记录自动统计
团队协作贡献	Git提交频率、代码行数、修改文件分布、分工合理性	TeamCoach贡献度报告	AI周报+教师确认
批判性思维	能否判断AI建议的有效性，给出采纳/拒绝理由	Code Review Battle辩论记录	小组汇报+教师观察
知识点掌握	能否将发现的问题对应到课程知识点	闯关修复+辩论发言	教师综合评估
验证能力	能否使用测试清单逐项验证修复效果	测试清单提交	测试通过率统计

终结性评价

评价维度	评价指标
代码实现	能否独立完成登录/登出与RBAC权限控制的完整实现
安全意识	能否识别常见的越权访问、Session残留等安全风险
视图一致性	能否在JSP中按角色正确渲染菜单

AI赋能的多维评价体系

评价工具	评价内容	评价类型	数据特点
WebSec挑战	通关数据：各关通过率、尝试次数、修复方案质量	过程性评价（安全能力）	客观、可量化、防作弊
TeamCoach	贡献度报告：代码提交、分工合理性、搭便车检测	团队评价（协作能力）	基于Git客观数据、AI分析
Code Review Battle	对战评分：发现问题数、质疑有效性、辩论深度	AI协作能力评价	人机对比、批判性维度
WebDev助教	提问记录：提问频次、问题深度、知识点覆盖	学习主动性评价	24h全时段、个性化

AI使用反思（课后必做）

请回答以下问题（200字以内）：

1. 在今天的攻防闯关和评审对战中，你的最大收获是什么？
2. AI在哪些方面超过了你的发现？你在哪些方面超过了AI？
3. 你认为"人机协同"在安全审查中的最佳模式是什么？

十、课程思政融入点

融入位置

阶段五（总结与反思，42-45分钟）

融入内容

以RBAC的"制度先行、权责明晰"类比社会治理：

1. **技术层面**：认证回答"你是谁"，授权回答"你能做什么"。最小权限、默认拒绝是安全设计的基石。
2. **社会治理层面**：任何系统（技术系统或社会系统）都需要规则和边界。用户分类、权限隔离，保障的是公平与安全。
3. **开发者责任**：作为技术人员，我们编写的每一行权限控制代码，都在守护用户的隐私与权益。依法治网、保护数据安全，是开发者的职业责任。

4. **AI伦理延伸**：AI工具强大但非万能，在安全领域尤需人的判断与把关——技术自主可控、人类主导决策，是负责任的AI使用观。

融入方式

- 自然过渡，不生硬说教。
- 从技术知识点（RBAC、最小权限）直接延伸到社会意义（规则、秩序、责任）。
- 结合《个人信息保护法》实施背景，强调开发者的法律义务。
- 从"人 vs AI"对战的课堂体验，自然引出AI伦理与人类主导的讨论。

十一、课后拓展任务

攻防闯关延续

- 完成WebSec挑战平台第4-5关（XSS跨站脚本、综合BOSS关），巩固安全知识。
- 排行榜持续更新，激励课后自主学习。

团队项目任务

- 在团队项目中实现用户认证与权限控制模块（登录/登出/RBAC）。
- TeamCoach将自动追踪各成员的贡献度，下次课前生成周报。

思考题

1. 如何防御"固定会话攻击"（Session Fixation）？登录成功后是否应更换`JSESSIONID`？
2. 如果一个页面既允许ADMIN也允许MANAGER访问，你会如何编排过滤器的判定逻辑与配置？

分层实践作业

层次	任务内容
基础	将密码哈希从SHA-256升级为BCrypt（如`BCrypt.checkpw`），对比彩虹表攻击下的安全性差异

层次	任务内容
进阶	为`/report/*`新增MANAGER角色的访问控制，实现三级权限（USER/MANAGER/ADMIN），并在JSP中新增对应菜单
挑战	增强Session安全：登录成功后重新生成Session ID、设置Session超时、实现"记住我"功能

智能体辅助学习

- 有任何疑问随时向WebDev助教提问，获取基于课程知识库的精准解答。
- 智能体会根据你的提问记录推荐个性化学习路径。

AI使用反思（必做）

请回答以下问题（200字以内）：

1. 在今天的攻防闯关和评审对战中，你的最大收获是什么？
2. AI在哪些方面超过了你的发现？你在哪些方面超过了AI？
3. 你认为"人机协同"在安全审查中的最佳模式是什么？

十二、AI教学情境覆盖说明

> *本节说明本讲45分钟课堂如何通过4项AI创新工具覆盖人工智能赛道要求的全部6个教学情境。*

赛道要求的6个情境与覆盖情况

赛道要求的情境	本讲覆盖方式	涉及阶段	涉及工具
① 学情数据采集与分析	课前WebDev助教自动采集42人提问数据，生成学情热力图；教师据此调整教学重点	阶段一（导入展示）	WebDev助教 + TeamCoach

赛道要求的情境	本讲覆盖方式	涉及阶段	涉及工具
② 数字资源整合与运用	WebDev助教基于RAG整合课程知识库（16讲课件+实验手册+常见错误库）；WebSec挑战平台AI动态生成漏洞代码题库	阶段二（闯关）+ 阶段四（答疑）	WebDev助教 + WebSec挑战
③ 适配的教学场景设计	WebSec挑战为每位学生生成个性化漏洞代码（自适应难度）；Code Review Battle设计人机对抗场景	阶段二（闯关）+ 阶段三（对战）	WebSec挑战 + Code Review Battle
④ 多维智能评价反馈	WebSec闯关数据（通过率+用时）+ Code Review Battle对战评分（人vs AI）+ TeamCoach贡献度报告 + WebDev助教提问记录 = 4维度过程性评价	全程	全部4个工具
⑤ 师生机协同教学	阶段二：AI出题->学生解题->教师据数据干预；阶段三：学生审查->AI审查->人机辩论->教师总结	阶段二 + 阶段三	WebSec挑战 + Code Review Battle
⑥ 个性化学习支持	WebDev助教24小时个性化问答；WebSec挑战自适应难度；TeamCoach标记薄弱学生->教师精准关注	阶段四（答疑+关注薄弱生）+ 课后	WebDev助教 + WebSec挑战 + TeamCoach

覆盖矩阵

赛道情境	WEBDEV助教	WEBSEC挑战	TEAMCOACH	CODE REVIEW BATTLE	覆盖工具数
① 学情数据采集与分析	★	○	★	—	2
② 数字资源整合与运用	★	★	—	—	2
③ 适配的教学场景设计	—	★	—	★	2
④ 多维智能评价反馈	★	★	★	★	4
⑤ 师生机协同教学	—	★	—	★	2

赛道情境	WEBDEV助教	WEBSEC挑战	TEAMCOACH	CODE REVIEW BATTLE	覆盖工具数
⑥ 个性化学习支持	★	★	★	—	3

结论：**4**项**AI**创新工具在**45**分钟课堂中覆盖全部**6**个赛道要求情境，远超"至少**2**个"的要求。每个情境均有至少**2**个工具支撑，情境④（多维智能评价反馈）由全部**4**个工具协同实现。